

Sec 5.4. Nmap: The Basics

1. Introduction

Nmap is a highly efficient network scanner that overcomes the limitations of basic tools like ping, arp-scan, and telnet to discover live devices and scan ports.

2. Host Discovery: Who Is Online

Nmap can be used to discover which hosts are currently online on a network.

Scanning a "Local" Network: `nmap -sn 192.168.66.0/24` command and its output are shown in the terminal below. As mentioned earlier, `-sn` aims to discover live hosts without attempting to discover the services running on them. This scan might be helpful if you want to discover the devices on a network without causing much noise. However, this won't tell us which services are running.

```
root@tryhackme:~# nmap -sn 192.168.66.0/24
Starting Nmap 7.92 ( https://nmap.org ) at 2024-08-07 13:49 EEST
Nmap scan report for XiaoQiang (192.168.66.1)
Host is up (0.0069s latency).
MAC Address: 44:DF:65:D8:FE:6C (Unknown)
Nmap scan report for S190023240007 (192.168.66.88)
Host is up (0.090s latency).
MAC Address: 7C:DF:A1:D3:8C:5C (Espressif)
Nmap scan report for wlan0 (192.168.66.97)
Host is up (0.20s latency).
MAC Address: 10:D5:61:E2:18:E6 (Tuya Smart)
Nmap scan report for 192.168.66.179
Host is up (0.10s latency).
MAC Address: E4:AA:EC:8F:88:C9 (Tianjin Hualai Technology)
[...]
Nmap done: 256 IP addresses (7 hosts up) scanned in 2.64 seconds
```

Nmap offers a list scan with the option `-sL`. This scan only lists the targets to scan without actually scanning them. For example, `nmap -sL 192.168.0.1/24` will list the 256 targets that will be scanned.

What is the last IP address that will be scanned when your scan target is 192.168.0.1/27?

`nmap -sL 192.168.0.1/27` answer 192.168.0.31

3. Port Scanning: Who Is Listening

Scanning TCP Ports: The easiest and most basic way to know whether a TCP port is open would be to attempt to telnet to the port. If you are inclined to scan with a Telnet client, try to establish a TCP connection with every target port.

Connect Scan: The connect scan can be triggered using `-sT`. It tries to complete the TCP three-way handshake with every target TCP port. If the TCP port turns out to be open and Nmap connects successfully, Nmap will tear down the established connection.

SYN Scan (Stealth): Unlike the connect scan, which tries to connect to the target TCP port, i.e., complete a three-way handshake, the SYN scan only executes the first step: it sends a TCP SYN packet. Consequently, the TCP three-way handshake is never completed. The advantage is that this is expected to lead to fewer logs as the connection is never established, and hence, it is considered a relatively stealthy scan. You can select the SYN scan using the `-sS` flag.

Scanning UDP Ports: Although most services use TCP for communication, many use UDP. Examples include DNS, DHCP, NTP (Network Time Protocol), SNMP (Simple Network Management Protocol), and VoIP (Voice over IP). UDP does not require establishing a connection and tearing it down afterwards. Furthermore, it is very suitable for real-time communication, such as live broadcasts.

Nmap offers the option `-sU` to scan for UDP services. Because UDP is simpler than TCP, we expect the traffic to differ. The screenshot below shows several ICMP destination unreachable (port unreachable) responses as Nmap sends UDP packets to closed UDP ports.

Scanning UDP Ports: Although most services use TCP for communication, many use UDP. Examples include DNS, DHCP, NTP (Network Time Protocol), SNMP (Simple Network Management Protocol), and VoIP (Voice over IP). UDP does not require establishing a connection and tearing it down afterwards.

Nmap offers the option `-sU` to scan for UDP services. Because UDP is simpler than TCP, we expect the traffic to differ.

Limiting the Target Ports: Nmap scans the most common 1,000 ports by default. However, this might not be what you are looking for. Therefore, Nmap offers you a few more options.

- `-F` is for Fast mode, which scans the 100 most common ports (instead of the default 1000).
- `-p[range]` allows you to specify a range of ports to scan. For example, `-p10-1024` scans from port 10 to port 1024, while `-p-25` will scan all the ports between 1 and 25. Note that `-p-` scans all the ports and is equivalent to `-p1-65535` and is the best option if you want to be as thorough as possible.

4. Summary-1

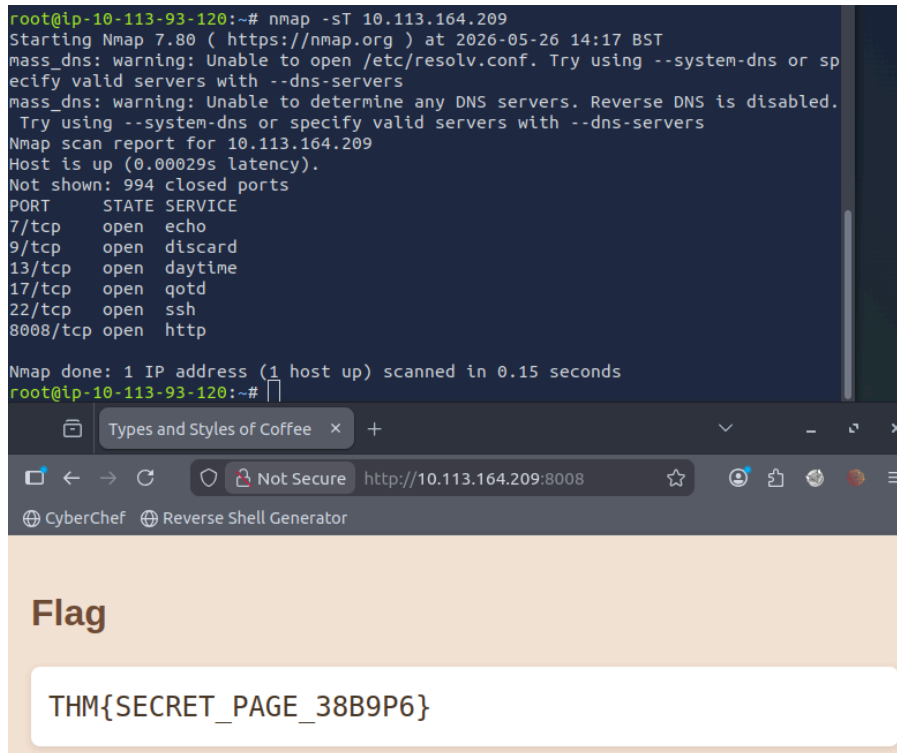
Option	Explanation
<code>-sT</code>	TCP connect scan – complete three-way handshake
<code>-sS</code>	TCP SYN – only first step of the three-way handshake
<code>-sU</code>	UDP scan
<code>-F</code>	Fast mode – scans the 100 most common ports
<code>-p[range]</code>	Specifies a range of port numbers – <code>-p-</code> scans all the ports

How many TCP ports are open on the target system at `10.113.164.209`?

A. 6 `nmap -sT 10.113.164.209`

Find the listening web server on `10.113.164.209` and access it with your browser. What is the flag that appears on its main page?

A. THM{SECRET_PAGE_38B9P6}



5. Version Detection: Extract More Information

OS Detection: You can enable OS detection by adding the `-O` option. As the name implies, the OS detection option triggers Nmap to rely on various indicators to make an educated guess about the target OS.

Service and Version Detection: You discovered several open ports and want to know what services are listening on them. `-sV` enables version detection. This is very convenient for gathering more information about your target with fewer keystrokes.

Forcing the Scan: When we run our port scan, such as using `-sS`, there is a possibility that the target host does not reply during the host discovery phase (e.g. a host doesn't reply to ICMP requests). Consequently, Nmap will mark this host as down and won't launch a port scan against it. We can ask Nmap to treat all hosts as online and port scan every host, including those that didn't respond during the host discovery phase. This choice can be triggered by adding the `-Pn` option.

6. Summary-2

Option	Explanation
<code>-O</code>	OS detection
<code>-sV</code>	Service and version detection
<code>-A</code>	OS detection, version detection, and other additions
<code>-Pn</code>	Scan hosts that appear to be down

What is the name and detected version of the web server running on 10.113.164.209?

lighttpd 1.4.74 (nmap -o 10.113.164.209)

7. Timing: How Fast is Fast

The table below should give you an idea, but you will get different results depending on the network setup and target system.

Timing	Total Duration
T0 (paranoid)	9.8 hours
T1 (sneaky)	27.53 minutes
T2 (polite)	40.56 seconds
T3 (normal)	0.15 seconds
T4 (aggressive)	0.13 seconds

A second helpful option is the number of parallel service probes. The number of parallel probes can be controlled with `--min-parallelism <numprobes>` and `--max-parallelism <numprobes>`. These options can be used to set a minimum and maximum on the number of TCP and UDP port probes active simultaneously for a host group. By default, `nmap` will automatically control the number of parallel probes. If the network is performing poorly, i.e., dropping packets, the number of parallel probes might fall to one; furthermore, if the network performs flawlessly, the number of parallel probes can reach several hundred.

A similar helpful option is the `--min-rate <number>` and `--max-rate <number>`. As the names indicate, they can control the minimum and maximum rates at which `nmap` sends packets. The rate is provided as the *number of packets per*

second. It is worth mentioning that the specified rate applies to the whole scan and not to a single host.

The last option we will cover in this task is `--host-timeout <time>`. This option specifies the maximum time you are willing to wait, and it is suitable for slow hosts or hosts with slow network connections.

Option	Explanation
<code>-T<0-5></code>	Timing template – paranoid (0), sneaky (1), polite (2), normal (3), aggressive (4), and insane (5)
<code>--min-parallelism <numprobes></code> and <code>--max-parallelism <numprobes></code>	Minimum and maximum number of parallel probes
<code>--min-rate <number></code> and <code>--max-rate <number></code>	Minimum and maximum rate (packets/second)
<code>--host-timeout</code>	Maximum amount of time to wait for a target host

What is the non-numeric equivalent of `-T4` ? Aggressive 0.13 seconds

8. Output: Controlling What You See

Verbosity: The best way to get more updates about what's happening is to enable verbose output by adding `-v`. Consider the following terminal output showing the network scan repeated twice. In the first case, we opted for the default output verbosity.

```
root@tryhackme:~# nmap -sS 192.168.139.1/24
Starting Nmap 7.92 ( https://nmap.org ) at 2024-08-13 18:57 EEST
Nmap scan report for 192.168.139.254
Host is up (0.000030s latency).
All 1000 scanned ports on 192.168.139.254 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 00:50:56:E0:FC:AE (VMware)

Nmap scan report for g5000 (192.168.139.1)
Host is up (0.000010s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
902/tcp   open  iss-realsecure
```

Then, we repeated the same scan; however, the second time, we used the `-v` option for verbosity. The amount of details present below can be very useful, especially when you are learning about Nmap and exploring the different options. In the terminal output below, we can see how Nmap is moving from one stage to another: ARP ping scan, parallel DNS resolution, and finally, SYN stealth scan for every live host.

```
root@tryhackme:~# nmap 192.168.139.1/24 -v
Starting Nmap 7.92 ( https://nmap.org ) at 2024-08-13 19:01 EEST
Initiating ARP Ping Scan at 19:01
Scanning 255 hosts [1 port/host]
Completed ARP Ping Scan at 19:01, 7.94s elapsed (255 total hosts)
Initiating Parallel DNS resolution of 1 host. at 19:01
Completed Parallel DNS resolution of 1 host. at 19:02, 13.00s elapsed
Nmap scan report for 192.168.139.0 [host down]
Nmap scan report for 192.168.139.2 [host down]
```

Most likely, the `-v` option is more than enough for verbose output; however, if you are still unsatisfied, you can increase the verbosity level by adding another "v" such as `-vv` or even `-vvvv`. You can also specify the verbosity level directly, for example, `-v2` and `-v4`. You can even increase the verbosity level by pressing "v" after the scan already started.

Debugging: If all this verbosity does not satisfy your needs, you must consider the `-d` for debugging-level output. Similarly, you can increase the debugging level by adding one or more "d" or by specifying the debugging level directly. The maximum level is `-d9`; before choosing that, make sure you are ready for thousands of information and debugging lines.

9. Saving Scan Report

Nmap gives us various formats. The three most useful are normal (human-friendly) output, XML output, and grepable output, in reference to the `grep` command. You can select the scan report format as follows:

- `-oN <filename>` - Normal output
- `-oX <filename>` - XML output
- `-oG <filename>` - `grep` able output (useful for `grep` and `awk`)

- `-oA <basename>` - Output in all major formats

In the terminal below, we can see an example of using the `-oA` option. It resulted in three reports with the extensions `nmap`, `xml`, and `gnmap` for normal, XML, and `grep`-able output.

```
root@tryhackme:~# nmap -sS 192.168.139.1 -oA gateway
Starting Nmap 7.92 ( https://nmap.org ) at 2024-08-13 19:35 EEST
Nmap scan report for g5000 (192.168.139.1)
Host is up (0.0000070s latency).
Not shown: 999 closed tcp ports (reset)
PORT      STATE SERVICE
902/tcp   open  iss-realsecure

Nmap done: 1 IP address (1 host up) scanned in 0.13 seconds
# ls
gateway.gnmap gateway.nmap gateway.xml
```

What option must you add to your nmap command to enable debugging?

What kind of scan will Nmap use if you run `nmap 10.113.164.209` with local user privileges? Connect Scan

10. Summary-3

It is worth noting that it is best to run Nmap with sudo privileges so that we can make use of all its features. Running Nmap with local user privileges will still work; however, you should expect many features to be unavailable.

Option	Explanation
<code>-sL</code>	List scan – list targets without scanning
Host Discovery	
<code>-sn</code>	Ping scan – host discovery only
Port Scanning	
<code>-sT</code>	TCP connect scan – complete three-way handshake
<code>-sS</code>	TCP SYN – only first step of the three-way handshake
<code>-sU</code>	UDP Scan

Option	Explanation
<code>-F</code>	Fast mode – scans the 100 most common ports
<code>-p[range]</code>	Specifies a range of port numbers – <code>-p-</code> scans all the ports
<code>-Pn</code>	Treat all hosts as online – scan hosts that appear to be down
Service Detection	
<code>-O</code>	OS detection
<code>-sV</code>	Service version detection
<code>-A</code>	OS detection, version detection, and other additions
Timing	
<code>-T<0-5></code>	Timing template – paranoid (0), sneaky (1), polite (2), normal (3), aggressive (4), and insane (5)
<code>--min-parallelism <numprobes></code> and <code>--max-parallelism <numprobes></code>	Minimum and maximum number of parallel probes
<code>--min-rate <number></code> and <code>--max-rate <number></code>	Minimum and maximum rate (packets/second)
<code>--host-timeout</code>	Maximum amount of time to wait for a target host
Real-time output	
<code>-v</code>	Verbosity level – for example, <code>-vv</code> and <code>-v4</code>
<code>-d</code>	Debugging level – for example <code>-d</code> and <code>-d9</code>
Report	
<code>-oN <filename></code>	Normal output
<code>-oX <filename></code>	XML output
<code>-oG <filename></code>	<code>grep</code> -able output
<code>-oA <basename></code>	Output in all major formats